24216276

INST0057 Information Governance

Elizabeth Lomas

Coursework 2- A Risk Register with a Risk Treatment Plan and a Business report

Table of Contents

Business Report ***3***

Executive Summary **3**

Organisational Context **4**

Mission and Purpose 4

Structure and Sector 4

Our Stakeholders 4

Critical Information Assets 4

Legal and Regulatory Obligations 4

Introduction and Scope **5**

Risk Management Approach **5**

Define Risk Limits 6

Define Risk Roles 6

Selection of Risk Controls 6

Risk Register Overview **6**

Prioritisation and Risk Scoring 7

Assessment of Controls and Risk Treatments 7

Recommendations and Implementation Plan **7**

Justification for Recommendations 7

Phased Implementation Plan 8

Implementation Roles and Responsibilities 8

Funding Rationale 8

Conclusion **8**

Bibliography ***9***

Appendix ***10***

Appendix A **10**

Appendix A.1: PESTLE 10

Appendix A.2: STEEPLE 10

Appendix B **11**

Appendix B.1: Operational Workflow Matrix 11

Appendix C **12**

Appendix C.1: Information Asset Register 12

Appendix C.2: Risk Evaluation Heat Map 13

Appendix C.3: Colour-Coded Risk Scoring Matrix 13

Appendix D **14**

Appendix D.1.1: Information Risk Register- Treatment 14

Appendix D.1.2: Information Risk Register xlsx 15

Appendix D:2 ..... **15**

Appendix D.2.1: Statement of Applicability for Patient Health Data 16

Appendix D.2.2: Statement of Applicability for Consent Records 16

Business Report

Executive Summary

Cierva Sana is a Uk-based non-profit organisation that delivers mobile maternal and neonatal health care services across Colombia. This report focuses on the information governance risks associated with Cierva Sana's mobile onboarding process and, data and consent management workflow. It is focused on handling sensitive patient health data through mobile devices and cloud-based systems.

The two critical information assets were identified to be **Patient Health Data** and **Consent Records**. These assets support patient onboarding, triage, alerts, and care planning, which are to be compliant with data protection laws.

A structured, asset-based risk assessment was carried out in line with ISO 27001 and the UK governments Orange Book. **Risk exposure** was calculated using a 5 × 5 likelihood-impact matrix, calculating a risk exposure score of **20 for Patient Health Data** and risk exposure score of **12 for Consent Records**. The risk exposure score for **Patient Health Data** exceeded Cierva Sana's defined risk appetite of 15 and was therefore treated. The risk exposure score for **Consent Records** was within the risk appetite, but due to its legal in validating data use, it was tolerated. It remains subject to monitoring and accountability measures.

Controls were selected from ISO 27001's **Statement of Applicability** to reduce residual risk and support regulatory compliance. These controls include A.5.11(information security policy), A.8.2.1(data classification), A.9.2.1(access control), A.10.1.1(encryption) and A.12.4.1(logging). The implementation of these controls reduced residual risks schools to 10 **Patient Health Data** for and 8 for **Consent Records**. These scores now being within the defined risk appetite.

Implementation planning is set in three phases and delivered by internal teams using existing infrastructure, requiring no major costs. This approach ensures that Cierva Sana remains in compliance with UK GDPR and Colombian Law 1581. The treatment plan supports the organisation core mission to deliver ethically managed, data-driven mobile kettles across low resource environments.
Senior leadership is advised to adopt the treatment plan and embed controls into routine governance cycles by conducting routine reviews, auditing procedures and training programmes to maintain oversight. This ensures ongoing accountability and operational resilience as Cierva Sana continues to scale its impact.

Organisational Context

Mission and Purpose

Cierva Sana is a UK-based non-profit digital health organisation working with clinics in Latin America (specifically in Colombia) to improve maternal and neonatal health outcomes. We work alongside local health clinics in underserved communities to deliver mobile health services powered by data analytics. Services include patient registration, symptom triage, and dashboard analytics. Our focus is on local delivery and collaboration design, promoting local ownership to support long-term community efforts towards maternal health care.

Structure and Sector

Cierva Sana operates in the third sector as a non-profit organisation. The organisational structure is flat and cross functional with central UK-based leadership and regional delivery teams across Latin America. We operate internationally, supporting local clinics and health ministries to provide community focused health services.

Our Stakeholders

Our Stakeholders include UK based leadership, technical and regional teams, and frontline health workers. As well as cloud service providers. We are also supported by philanthropic funding partners to support infrastructure, software, and funding.

Critical Information Assets

Our services depend on the reliable handling of sensitive digital information. These critical assets include

- Patient health data
- Digital consent records
- Mobile app Logs
- Cloud-stored Analytics

These assets support patient onboarding, triage and alerts, and care planning. Protecting this information is critical to maintain patient confidentiality and meet the compliance obligations given by ISO 27000. Without proper safeguards for these assets, we risk regulatory breaches that could undermine stakeholder trust.

Legal and Regulatory Obligations

Cierva Sana operates under dual jurisdictions. In the UK, we operate under UK GDPR (1) and the Data Protection Act 2018 (2). In Columbia, we must comply with Ley 1581 de 2012 (3) (4) and associated national health data protection frameworks.

Our governance framework is informed by ISO 27001. We are also informed by WHO's digital ethical guidance (5). Within our organisation, we aim to prioritise the ethical use of data, data minimisation and secure access management.

Introduction and Scope

This report examines the information governance risk associated with Cierva Sana's mobile onboarding and data management process, focusing on the collection, storage, and use of sensitive data including patient health records and digital consent. These assets are handled through mobile devices and cloud-based systems.

Given Cierva Sana's decentralised and cross-border delivery model, robust risk management is essential to maintain data integrity to meet regulatory obligations and support reliable digital services in underserved communities.
Patient health data is a critical asset that supports remote maternal health triage and patient monitoring. Improper handling of it could undermine service reliability, compromise compliance and trust.

The scope covered within this report includes:

- Risk assessment of critical information assets
- Justification of treatment strategies
- Implementation planning of controls aligned with ISO standards
- Operational and compliance impacts.

It aims to ensure that critical health data is managed responsibly and in accordance with ISO 27001 standards and Cierva Sana's core values.

This report informs senior leadership of key risks and presents a proportionate implementation plan based on available internal resources. Recommendations directly support strategic objectives: improving service delivery, complying with international data laws, and reinforcing the resilience of digital health services.

Risk Management Approach

Our approach follows ISO 27000 principals and guidance from the Orange Book (6), using structured processes for identifying, assessing, and treating risk in alignment with Cierva Sana's goals. The framework utilises asset-based procedures that focus on supporting structured risk evaluation and treatment. We identified critical assets using an Information Asset Risk Register *(Appendix C.1: Information Asset Register)* and evaluated threats using a 5x5 qualitative matrix (*Appendix C.3: Colour-Coded Risk Scoring Matrix)*.

We applied a qualitative risk assessment method, using a likelihood-impact ratings to calculate risk exposure scores. Likelihood ratings ranged from "Very Unlikely" to "Very High" (*Table 1),* while impact assessed both operational and financial distribution *(Table 2)*.

Risk exposure was calculated by multiplying the scores on a 1-5 scale.

$$\text{Likelihood} \times \text{Impact} = \text{Risk Score}$$

*[**Equation 1**: Calculation for Risk Score]*

This score could be visualised using a colour-coded risk evaluation heat map *(Appendix C.2: Risk Evaluation Heat Map)* to help visualise and prioritise areas of relative severity risks.

Rating	Likelihood
Very High (5)	Definte
High (4)	Probable
Medium (3)	Possible
Low (2)	Unlikely
Very Low (1)	Extremely Unlikely

***Table 1**: Likelihood Rating Mapping*

IMPACT	Financial	Operational
Very High (5)	>500K	Cancellation
High (4)	£100 - £500K	Severe Distruption
Medium (3)	£50 - £100K	Significant distruption
Low (2)	£25 - £50K	Requires corrective action
Very Low (1)	<£25K	Requires noting

***Table 2**: Value/ Impact Mapping*

Define Risk Limits

Cierva Sana's **risk appetite is defined as 15**. Risks with exposure scores of ≤ 15 may tolerated or optionally be treated. However, scores > 15 must be treated, transferred, or escalated.

This threshold reflects a willingness to absorb moderate operational risk. These could include temporary disruptions (e.g., short-term app downtime). This moderate risk appetite supports the prioritisation of legal and ethical requirements.

The appetite level was set following a review of the service delivery requirement, taking into consideration any uncontrollable vulnerabilities.

Define Risk Roles

The roles and responsibilities for managing risk have been defined in alignment with ISO 27001:

- Risk owners: Health Programme Lead
- Asset owners: Technical Team Lead
- Implementing Authority: IT Security

These responsibilities are embedded in operational structures, supported by scheduled reviews with regular reporting.

Selection of Risk Controls

We identified treatment options high-risk assets using ISO 27001's **Statement of Applicability** (SoA). Controls were chosen based on:

- Alignment with regulatory duties
- Feasibility within current systems
- Capacity to reduce risk to within appetite

Once the treatment options are implemented, residual risk would be rescored and then monitored for changes.

A **PESTLE** and **STEEPLE** analysis *(Appendix A)* supported the process for identifying assets that may have more underlying importance.

Risk Register Overview

Our **Information Asset Register** identified five key information assets integral in the onboarding process and patient data management:

1. **Outreach Staff**: agents for consent collection and community engagement.
2. **Cloud Storage Server** (UK-based): infrastructure for recordkeeping and analytics.
3. **Mobile Onboarding Application**: client-facing platform for data entry.
4. **Patient Health Data**: sensitive health records that are managed through the platform.
5. **Consent Records**: legal basis for data processing and cross-border sharing to UK servers.

The highest scoring assets were:

- **Patient Health Data:**
  $4 \times 5 = \mathbf{20}$
- **Consent Records:**
  $3 \times 4 = \mathbf{12}$

Prioritisation and Risk Scoring

Patient Health Data exceeded the risk appetite and was treated. This high score reflects the likelihood of threats such as data access misuse. Any compromises could result in high legal consequences.

On the other hand, the exposure score is within appetite for **Consent Records.** Issues (e.g., network limitation) could lead to sever regulatory risk. This risk can be seen implied across steps 4-6 of the Operational Workflow Matrix *(Appendix B.1: Operational Workflow Matrix* Appendix B.1:*)*.

Therefore, we treat the asset under a "Tolerate" approach to maintain traceability and compliant storage according to its legal importance.

Assessment of Controls and Risk Treatments

During the risk evaluation process, control gaps were identified for **Patient Health Data** and **Consent Records** including lack of structured data encryption policies, inconsistent user-access management, and minimal audit log coverage.

To address these, treatments were implemented using ISO 27001 controls.
We implemented procedures aligned with controls A.5.1.1, A.9.2.1, A.10.1.1, and A.12.4.1 for **Patient Health Data** and A.7.2.2, A.8.2.1, A.9.2.5, A.9.4.1, A.12.4.1, and A.18.1.4 for **Consent Records.**

Residual risk scores were re-calculated and reviewed against our appetite threshold to confirm that the treatment implementation was effective.

Recommendations and Implementation Plan

To reduce the **high-risk exposure score of 20** for **Patient Health Data**, a risk 'treatment' approach was adopted.

The proposed actions involved strengthening security controls to reduce the risk of unauthorised access, data loss, or misuse. The controls were drawn primarily from ISO 27001 controls.
The treatment plan incorporates stricter access controls, improves data classification, comprehensive user activity logging, and enforces encryption protocols for data in-storage and during cross-border transfer.

For **Consent Records**, we adopted a "tolerate" treatment, as the **risk exposure score of 12** remained within our defined appetite. Our focuses were on maintaining oversight and accountability.
Traceability is maintained by applying access restrictions, conducting regular reviews of user permissions and system activity to confirm process integrity.

The implementation of the ISO controls reduced the residual risk for **Patient Health Data** and **Consent Records** to a score of 10 and 8 respectively. This placed the scores within the risk appetite.

- The implementation of these controls is documented in the SoA. *(Please find Information Register, under the name '24216276_INST0057_CW2.xlsx', in the uploaded Excel document.*

)

Justification for Recommendations

This treatment strategy was selected for **Patient Health Data** due to its critical role in service delivery as well as its direct reliance on confidentiality. The asset contains highly sensitive health data which is accessed regularly throughout the mobile onboarding and care planning process. A breach of this asset could result in severe regulatory violations under GDPR, as well as reputational damage due to loss of patients' confidence.

For **Consent Records**, the treatment was informed by its legal function in validating the collection and use of health data. The risk, while within the appetite, could result in non-compliance with UK GDPR or Colombian health laws if not properly monitored. Consent must be traceable, securely stored, and verifiable under privacy requirements.

These treatments *(Appendix D.1.1: Information Risk Register- Treatment),* are justified through the SoA.

Phased Implementation Plan

Phase 1: System access controls and encryption (2 weeks).

This is supported by existing IT infrastructure and policies.

Phase 2: Data classification and role-based access alignment. (2- 4 weeks)

Coordinated between the HR and IT security to ensure that access rights align with staff roles.

Phase 3: Enable and monitor system logging and audit trail validation (2 weeks).

Each phase builds on available technical infrastructure to ensure manageable implementation without disruption to services. Progress will be reviewed at each phase by the Health Programme Lead.

Implementation Roles and Responsibilities

Treatments for Patient Health Data will be implemented using in-house teams.

- **IT Security Team**: Implements encryption, logs, and configure access settings.
- **Health Programme Lead**: Oversee risk and provides approval to implementation.
- **Compliance Officer**: Ensures legal compliance.
- **HR Team**: Aligns user roles with appropriate permissions.

Consent Records have the responsibility of monitoring access controls, system logs, and record traceability shared between the Compliance Officer and Product/Technology Lead.

All the responsibilities reflect ISO 27001 expectations for operational integration and role accountability.

Funding Rationale

All controls will be implemented using in-house teams and existing systems. No major costs are involved. Tasks such as log monitoring, consent verification, and access verification will be added to ongoing staff responsibilities and reviewed periodically.

This approach minimises cost and avoids duplicating existing capabilities as it ensures efficient use of resources.

Conclusion

Overall, we were able to develop a treatment plan that utilises risk to assess how any underlying factors to a project's success are minimised.

As part of our Treatment Plan, we first developed a Process Matrix that details the proposed user journey for the application. This matrix was informed by a PESTLE analysis that provided ethical considerations into the main features for the application.
Together these provided the foundation to create an Information Risk Register for all the identified assets.

The Information Risk Register directed focus to the two assets identified to have the greatest risk implications if risk was ignored, **Patient Health Data** and **Consent Records.**
The Information Risk Register and corresponding treatments offer Cierva Sana a comprehensive model for identifying, scoring, and manging digital risks. It provides a structured framework for capturing data that allows for effective prioritisation of issues that are most imperative to upholding an organisation's ability to meet expected governance standards. By applying ISO 27001 controls and defining clear governance roles, this approach streamlines compliance and operational continuity.

This framework is also favourable to Cierva Sana's expansion, as it supports the delivery of a lawfully safe, ethically managed maternal and neonatal health services.

It is recommended that senior leadership adopt the treatment plan and maintain continuous oversight through routine reviews, training and auditing procedures embedded in existing workflows.

We have a commitment to deliver ethical and secure data-drive mobile care tools, so it is important that risk is not ignored but is mitigated through strategic means to achieve compliance.

Total Words: 1653

Bibliography

1. **The National Archives.** Regulation (EU) 2016/679 - General Data Protection Regulation (GDPR). *legislation.gov.uk*. [Online] 27 April 2016. https://www.legislation.gov.uk/eur/2016/679/contents.
2. —. Data Protection Act 2018. *legislation.gov.uk*. [Online] 23 May 2018. https://www.legislation.gov.uk/ukpga/2018/12/contents/enacted.
3. **DLA Piper.** Colombia - Data Protection Overview. *DLA Piper Data Protection Laws of the World*. [Online] 2023. https://www.dlapiperdataprotection.com/index.html?t=law&c=CO.
4. **Government of Colombia.** Ley 1581 de 2012. *Presidencia de la República de Colombia*. [Online] 17 October 2012. https://www.funcionpublica.gov.co/eva/gestornormativo/norma.php?i=49981.
5. **World Health Organization.** *Ethics and Governance of Artificial Intelligence for Health*. Geneva : World Health Organization , 2021. pp. 17-30 .
6. **HM Treasury .** *The Orange Book: Management of Risk – Principles and Concepts* . London : HM Government , 2023 .
7. **Standardization, International Organization for.** *ISO/IEC 27000:2018 – Information security management systems – Overview and vocabulary* . Geneva : ISO/IEC , 2018 .

Appendix

Appendix A

Appendix A.1: PESTLE

Factor	Description
Political	Operates in UK and Latin America (Colombia) requiring compliance with varied health policies, data sovereignty regulations. Navigates shifting governmental priorities, including changes in funding and health policy.
Economic	Dependent on grant funding, philanthropic support, and NGO partnerships. Subject to funding instability during global economic downturns.
Socio-cultural	Works with multilingual communities that often have low literacy level. People's beliefs about health, gender roles, and their comfortability with technology influence how consent is given and their engagement with the service.
Technological	Relies on mobile apps and cloud systems to deliver services. Users often face challenges with low digital confidence, limited access to smartphones, and poor network coverage in rural areas.
Legal	Must comply with both UK GDPR and Colombian data protection laws. These rules differ in how they handle data sharing, consent, and third-party access to information.
Environmental	Services operate in areas where weak infrastructure or extreme weather can disrupt internet access and the use of mobile devices making it harder to maintain consistent service delivery.

Appendix A.2: STEEPLE

Committed to informed consent, minimal data use, equitable access, and community-led delivery. Guided by WHO digital health ethics frameworks to promote transparency, inclusion, and accountability in data use and AI-driven triage.

Appendix B

Appendix B.1: Operational Workflow Matrix

Operational Workflow Matrix illustrating the step-by-step process for patient registration, consent coma and they trust synchronisation used in Cierva Sana's mobile health application.

Step	Action	Input condition	Decision Rule	Output	Next Step
1	Intial Engagement.	Outreach staff present with mobile device.	IF device launches successfully, THEN proceed.	App ready.	Step 2
2	Register patient in app.	Internet acess OR local offline storage.	IF NO network, store locally and retry in 24 hours.	Patient record initiated.	Step 3
3	Patient Identification & Demographics.	Patient willing to participate.	IF NO patient ID, THEN proceed with basic demographic entry.	Patient demographic data (eg., Name, age, location), national ID (if applicable), pregnancy status confirmation uploaded.	Step 4
4	Digital Consent Collection	Patient literate or assisted (Privacy and data usage policy explained in patient's language).	IF NO consent, THEN stop process.	Consent record (via digital signature or checkbox).	Step 5 or Exit
5	Health Data Entry	Consent given, health data available.	IF incomplete data, THEN prompt for retry.	Key health metrics entered (e.g., BP, weight, symptions).	Step 6
6	Triage and Alert Trigger	Health data entered.	IF risk score ≥ threshold, THEN flag case.	Risk score and alert flag.	Step 7
7	Care Plan Configuration	Risk score available.	IF flagged high-risk, THEN enable daily monitoring.	Personalised care plan (automatic scheduling of messages/ reminders via SMS or push notifications).	Step 8
8	Data Synchronisation	Device online or offline.	IF offline, THEN store locally; IF online, THEN upload data.	Encrypted uplood to UK-based server with confirmation recipt logged.	Step 9 or retry
9	Patient Record Completed	Data sync confirmed.	All records valid and care plan active THEN end onboarding.	Full digital patient record (Digital file generated, Risk classification completed, Care plan activated in dashboard).	End

Appendix C

Appendix C.1: Information Asset Register

This table records key information assets, the owners, formats, locations, and associated risks. It forms the basis for risk scoring and treatment planning.

Asset ID	Asset Name (Information Asset)	Owner	Format	Location	Value/ Impact	Likelihood	Risk Exposure	Explanation
1	Outreach Staff	Regional Programme Manager	People	Field locations across Colombia	4 - Misuse could cause severe operational disruption	3 - Outreach Staff operate in uncontrolled environments, increasing the likelihood of human error or improper use	12	Within appetite (≤15); may be tolerated but requires monitoring due to field variability and human error risk.
2	Cloud Storage Server (UK-based)	IT Department (UK-based)	Digital/ Infrastructure	UK-based Cloud Server (encrypted)	5 - A breach or misconfiguration could compromise the entire system's availability and data integrity	2 - Cloud infrastructure in managed professionally with high security standards	10	Within appetite (≤15); accepted due to strong security controls and low likelihood of failure.
3	Mobile Onboarding Application	Product/ Technolgy Lead	Software	Mobile devices used by patients	4 - Failure disrupts registration and triage processes	3 - App failures or outdated software may occur in the field due to limited connectivity and update access	12	Within appetite (≤15); may be tolerated but should undergo periodic reviews for update and stability risks.
4	Patient Health Data	Health Programme Lead	Digital (text/ data files)	Encrypted database in cloud system	5 - A data breach could lead to regulatory penalties and reputational consequences	4 - Health data is frequently accessed and highly sensitive	20	Exceed appetite (>15); Mitigation or treatment needed due to high sensitivity and regulatory impact.
5	Consent Records (e.g., Digital Signatures)	Compliance Officer	Digital (documents/ logs)	Encrypted database in cloud system	4 - Missing consent invalidates lawful data use	3 - Issues may occur during consent collection or data synchronization, particularly in areas with limited network access	12	Within appetite (≤15); may be tolerated but with regular review on consent tracking and log reliability to ensure compliance.

Appendix C.2: Risk Evaluation Heat Map

A visual tool mapping likelihood against impact, with colour coding with green (low) to red (high), highlighting which risks require immediate attention.

		Impact				
		Negligible	Minor	Moderate	Significant	Severe
Likelihood	Very Likely	Low Med	Medium	Med Hi	High	High
	Likely	Low	Low Med	Medium	Med Hi	High
	Possible	Low	Low Med	Medium	Med Hi	Med Hi
	Unlikely	Low	Low Med	Low Med	Medium	Med Hi
	Very Unlikely	Low	Low	Low Med	Medium	Medium

Appendix C.3: Colour-Coded Risk Scoring Matrix

A risk scoring matrix that calculates risk exposure by multiplying likelihood and impact scores. Colour coding "red" identify risks that exceed the appetite threshold.

		Impact				
		1	2	3	4	5
Likelihood	1	1	2	3	4	5
	2	2	4	6	8	10
	3	3	6	9	12	15
	4	4	8	12	16	20
	5	5	10	15	20	25

Appendix D

Appendix D.1.1: Information Risk Register- Treatment

	ASSET TITLE	VALUE/ IMPACT	THREAT/VULNERABILITY (RISK DESCRIPTION)	LIKELI-HOOD	RISK EXPOSURE	TREATMENT	LIKELI-HOOD
1	Outreach Staff	4 - Misuse could cause severe operational disruption.	Lack of security training, unmonitored device use, inconsistent policy enforcement.	3	12	No treatment	n/a
2	Cloud Storage Server (UK-based)	5 - A breach or misconfiguration could compromise the entire system's availability and data integrity.	Inadequate encryption, insufficient access controls, third-party dependency.	2	10	No treatment	n/a
3	Mobile Onboarding Application	4 - Misuse could cause severe operational disruption.	Use of outdated app versions, missing security patches, weak user authentication.	3	12	No treatment	n/a
4	Patient Health Data	5 - A data breach could lead to regulatory penalties and reputational consequences	Insufficient data minimisation, inadequate backup protocols, poorly defined access controls	4	20	Enhanced encryption, strict access controls, data classification rules, and system logging controls implemented based on ISO 27001 to reduce exposure by ensuring confidentiality, trace ability and appropriate data handling throughout the system.	2
5	Consent Records (e.g., Digital Signatures)	4 - Missing consent invalidates lawful data use	Unreliable synchronisation of consent records between the app and cloud server, missing audit trails, invalid consent logging during data entry.	3	12	Access to consent records is restricted to authorised users, with access reviewed regularly and all activity logged. Staff receive training, and records are classified and protected under privacy law. These treatments support a "Tolerate" strategy using existing systems and ISO 27001.	2

Appendix D.1.2: Information Risk Register xlsx

Please find Information Register, under the name '24216276_INST0057_CW2.xlsx', in the uploaded Excel document.

Appendix D:2

Appendix D.2.1: Statement of Applicability for Patient Health Data

Name of Organisation **SOA ISO/IEC 27001:2017**

Statement of Applicability: Patient Health Data

Highlighted main control that must be adopted.

A.5 Information Security Policies

A .5.1 Management Direction for Information Security

Control	Description	Adopted	Justification	Reference
A.5.1.1	Policies for information security	Y	Policies govern secure handling of high-risk patient data protected under GDPR.	Information Security Policy Manual
A.5.1.2	Review of the policies for information security	Y	Patient data policies are reviewed regularly to reflect GDPR changes and emerging risks.	Information Security Policy Manual

A.6 Organisation of Information Security

A.6.1 Internal Organisation

Control	Description	Adopted	Justification	Reference

A.6.1.1	Information security roles and responsibilities	Y	Defined roles for managing patient data or reduce risk of oversight	Information Security Policy Manual
A.6.1.2	Segregation of duties	Y	Data access and auditors are separated to minimise risk	ISMS Operational Manual
A.6.1.3	Contact with authorities	Y	Required for reporting data breaches involving health records	Incident Response Procedure
A.6.1.4	Contact with special interest groups	N	Not relevant.	N/A
A.6.1.5	Information security in project management	Y	Security considerations are integrated into systems that handle patient data	Governance and Continuity Framework

A.6.2 Mobile Devices and Teleworking

Control	Description	Adopted	Justification	Reference
A.6.2.1	Mobile device policy	Y	mobile access to patient data is governed by encryption app use policies	Staff Handbook
A.6.2.2	Teleworking	Y	remote access to patient records is secured	Staff Handbook

A.7 Human Resource Security

A.7.1 Prior to Employment

Control	Description	Adopted	Justification	Reference

A.7.1.1	Screening	Y	Staff with access to patient data are background checked.	Staff Handbook
A.7.1.2	Terms and conditions of employment	Y	Employment contracts include data protection responsibilities.	Staff Handbook

A.7.2 During Employment

Control	Description	Adopted	Justification	Reference
A.7.2.1	Management responsibilities	Y	Managers are accountable for data handling within their teams.	Staff Handbook
A.7.2.2	Information security awareness, education and training	Y	Staff trained on patient data handling and data protection.	Staff Handbook
A.7.2.3	Disciplinary process	Y	Breaches of patient data policy are subject to discipline.	Staff Handbook

A.7.3 Termination and Change of Employment

Control	Description	Adopted	Justification	Reference
A.7.3.1	Termination or change of employment responsibilities	Y	Data access is revoked when roles change or employment ends.	ISMS Operational Manual

A.8 Asset Management

A.8.1 Responsibility for Assets

Control	Description	Adopted	Justification	Reference
A.8.1.1	Inventory of assets	Y	Patient data is listed in the asset register.	Governance and Continuity Framework
A.8.1.2	Ownership of assets	Y	Data assigned for patient records.	ISMS Operational Manual
A.8.1.3	Acceptable use of assets	Y	Staff follow defined rules for patient data use.	Information Security Policy Manual
A.8.1.4	Return of assets	Y	Data access revoked when roles change or end.	ISMS Operational Manual

A.8.2 Information Classification

Control	Description	Adopted	Justification	Reference
A.8.2.1	Classification of information	Y	Patient data is classified as sensitive personal data.	ISMS Operational Manual
A.8.2.2	Labelling of information	Y	Sensitive records marked as “confidential” in system.	ISMS Operational Manual
A.8.2.3	Handling of assets	Y	Staff trained on how to handle patient data securely.	Staff Handbook

A.8.3 Media Handling

Control	Description	Adopted	Justification	Reference
A.8.3.1	Management of removable media	N	Patient data not stored on removable media.	N/A
A.8.3.2	Disposal of media	Y	Secure deletion procedures followed for obsolete records.	ISMS Operational Manual
A.8.3.3	Physical media transfer	N	Patient data not transferred using physical media.	N/A

A.9 Access Control

A.9.1 Business Requirements of Access Control

Control	Description	Adopted	Justification	Reference
A.9.1.1	Access control policy	Y	Policy defines how access to patient data is controlled and enforced.	Information Security Policy Manual
A.9.1.2	Access to networks and network services	Y	Network access to patient data systems is role based and restricted.	Information Security Policy Manual

A.9.2 User Access Management

Control	Description	Adopted	Justification	Reference
A.9.2.1	User registration and de-registration	Y	All users accessing patient data must be registered and deregistered promptly	ISMS Operational Manual

A.9.2.2	User access provisioning	Y	access to patient data is provisioned according to defined roles.	Information Security Policy Manual
A.9.2.3	Management of privileged access rights	Y	Privileged access to patient systems is limited and documented.	ISMS Operational Manual
A.9.2.4	Management of secret authentication information of users	Y	Authentication credentials are securely stored and maintained.	Information Security Policy Manual
A.9.2.5	Review of user access rights	Y	Access rights for users of patient data are reviewed regularly.	ISMS Operational Manual
A.9.2.6	Removal or adjustment of access rights	Y	Access to patient data is removed or adjusted when roles change.	ISMS Operational Manual

A.9.3 User Responsibilities

Control	Description	Adopted	Justification	Reference
A.9.3.1	Use of secret authentication information	Y	Users are trained to securely handle authentication information.	Security Awareness Manual

A.9.4 System and Application Access Control

Control	Description	Adopted	Justification	Reference
A.9.4.1	Information access restriction	Y	Patient data access is restricted using system level access controls.	ISMS Operational Manual

A.9.4.2	Secure log-on procedures	Y	Log on procedures ensure secure access to patient data systems.	ISMS Operational Manual
A.9.4.3	Password management system	Y	Password rules are enforced for system storing patient records.	Information Security Policy Manual
A.9.4.4	Use of privileged utility programs	Y	Privilege utilities are restricted to authorised system administrators.	ISMS Operational Manual
A.9.4.5	Access control to program source code	Y	Not applicable to patient data which does not involve source code access.	N/A

A.10 Cryptography

A.10.1 Cryptographic Controls

Control	Description	Adopted	Justification	Reference
A.10.1.1	Policy on the use of cryptographic controls	Y	Encryption is required to protect health data well stored and during transmission.	Information Security Policy Manual
A.10.1.2	Key management	Y	Keys for encrypted health data are securely generated stored.	Information Security Policy Manual

A.11 Physical and Environmental Security

A.11.1 Secure Areas

Control	Description	Adopted	Justification	Reference
A.11.1.1	Physical security perimeter	N	Data is cloud based and not dependent on perimeter controls.	N/A
A.11.1.2	Physical entry controls	Y	Entry to offices handling health data is access controlled.	Staff Handbook
A.11.1.3	Securing offices, rooms and facilities	Y	Rooms with access to data are locked and access restricted.	Staff Handbook
A.11.1.4	Protecting against external and environmental threats	Y	Critical areas have basic environmental controls, such as emergency power solutions and locked access points.	Governance and Continuity Framework
A.11.1.5	Working in secure areas	Y	Access to health data is only permitted in secure locations.	Information Security Policy Manual
A.11.1.6	Delivery and loading areas	N	Not relevant	N/A

A.11.2 Equipment

Control	Description	Adopted	Justification	Reference
A.11.2.1	Equipment siting and protection	Y	Equipment is located unprotected to reduce risk from access or environmental threats.	ISMS Operational Manual
A.11.2.2	Supporting utilities	N	Not applicable.	N/A
A.11.2.3	Cabling security	N	Not relevant.	N/A
A.11.2.4	Equipment maintenance	N	Devices are replaced instead of maintained.	N/A
A.11.2.5	Removal of assets	Y	Devices are returned or access removed when roles change.	ISMS Operational Manual
A.11.2.6	Security of equipment and assets off-premises	Y	Off-premises equipment is protected to prevent unauthorised access.	Staff Handbook

A.11.2.7	Secure disposal or re-use of equipment	Y	Devices are securely wiped before disposal or reuse.	ISMS Operational Manual
A.11.2.8	Unattended user equipment	Y	Devices unlocked when unattended.	ISMS Operational Manual
A.11.2.9	Clear desk and clear screen policy	Y	Staff follow screen and desk policy to protect visible data.	Staff Handbook

A.12 Operations Security

A.12.1 Operational Procedures and Responsibilities

Control	Description	Adopted	Justification	Reference
A.12.1.1	Documented operating procedures	Y	Procedures guide how patient data is handled and accessed.	ISMS Operational Manual
A.12.1.2	Change management	Y	Changes to data systems follow a review process.	ISMS Operational Manual
A.12.1.3	Capacity management	N	Not relevant.	N/A
A.12.1.4	Separation of development, testing and operational environments	N	Not applicable.	N/A

A.12.2. Protection from Malware

Control	Description	Adopted	Justification	Reference

A.12.2.1	Controls against malware	Y	Devices used for health data have anti malware software.	Device security SOP

A.12.3 Backup

Control	Description	Adopted	Justification	Reference
A.12.3.1	Information backup	Y	Patient data is backed up regularly to ensure availability.	ISMS Operational Manual

A.12.4 Logging and Monitoring

Control	Description	Adopted	Justification	Reference
A.12.4.1	Event logging	Y	Access to health data is logged for trace ability.	ISMS Operational Manual
A.12.4.2	Protection of log information	Y	Logs are secured against tampering or loss.	ISMS Operational Manual
A.12.4.3	Administrator and operator logs	Y	Actions by system administrators are logged.	ISMS Operational Manual
A.12.4.4	Clock synchronisation	Y	System clocks are synched to ensure accurate log timestamps.	ISMS Operational Manual

A.12.5 Control of Operational Software

Control	Description	Adopted	Justification	Reference
A.12.5.1	Installation of software on operational systems	Y	Software installations are controlled on systems handling patient data.	ISMS Operational Manual

A.12.6 Technical vulnerability Management

Control	Description	Adopted	Justification	Reference
A.12.6.1	Management of technical vulnerabilities	Y	Vulnerabilities are tracked and addressed on data systems.	ISMS Operational Manual
A.12.6.2	Restrictions on software installation	Y	Only authorised software is permitted on systems with patient data.	ISMS Operational Manual

A.12.7.1 Information Systems Audit Considerations

Control	Description	Adopted	Justification	Reference
A.12.7.1	Information systems audit controls	Y	Systems that store patient data are auditable.	Audit & Compliance Logbook

A.13 Communication Security

A.13.1 Network Security Management

Control	Description	Adopted	Justification	Reference
A.13.1.1	Network controls	Y	network controls in place to protect access to patient data.	Information Security Policy Manual
A.13.1.2	Security of network services	Y	Data systems use secure network services to prevent breaches.	Information Security Policy Manual
A.13.1.3	Segregation in networks	N	No network segmentation used for patient data systems.	N/A

A.13.2 Information Transfer

Control	Description	Adopted	Justification	Reference
A.13.2.1	Information transfer policies and procedures	Y	policies define how patient data is shared securely.	Supplier & Third-Party Security Pack
A.13.2.2	Agreements on information transfer	Y	Agreements cover data sharing with clinics and partners.	Supplier & Third-Party Security Pack
A.13.2.3	Electronic messaging	Y	Health data is not sent over unsecured messaging platforms.	Supplier & Third-Party Security Pack
A.13.2.4	Confidentiality or non-disclosure agreements	Y	NDA's are signed by staff handling patient records.	Staff Handbook

A.14 System Acquisition, Development and Maintenance

A.14.1 Security Requirements of Information Systems

Control	Description	Adopted	Justification	Reference
A.14.1.1	Information security requirements analysis and specification	Y	Security requirements are defined for systems handling patient data.	ISMS Operational Manual
A.14.1.2	Securing application services on public networks	Y	Health data systems use secure connections when accessed on public networks.	Information Security Policy Manual
A.14.1.3	Protecting application services transactions	Y	Transactions involving patient data are encrypted.	Information Security Policy Manual

A.14.2 Security in Development and Support Processes

Control	Description	Adopted	Justification	Reference
A.14.2.1	Secure development policy	Y	Secure development practises are followed for health data systems.	ISMS Operational Manual
A.14.2.2	System change control procedures	Y	Changes to data systems are documented and approved.	ISMS Operational Manual
A.14.2.3	Technical review of applications after operating platform changes	N	Not applicable.	N/A
A.14.2.4	Restrictions on changes to software packages	Y	Software updates are restricted on patient data systems.	ISMS Operational Manual
A.14.2.5	Secure system engineering principles	Y	Engineering principles applied to ensure patient data is protected.	ISMS Operational Manual
A.14.2.6	Secure development environment	Y	Environments for health data apps are access controlled.	ISMS Operational Manual

A.14.2.7	Outsourced development	Y	External developers follow contractual security obligations.	Supplier & Third-Party Security Pack
A.14.2.8	System security testing	Y	Health data systems are tested for security before release.	ISMS Operational Manual
A.14.2.9	System acceptance testing	Y	Systems are tested before use with patient records.	Audit & Compliance Logbook

A.14.3 Test Data

Control	Description	Adopted	Justification	Reference
A.14.3.1	Protection of test data	Y	Real patient data is not used in test environment.	ISMS Operational Manual

A.15 Supplier Relationships

A.15.1 Information Security in Supplier Relationships

Control	Description	Adopted	Justification	Reference
A.15.1.1	Information security policy for supplier relationships	Y	Policy defines data security for supplier relationships.	Supplier & Third-Party Security Pack
A.15.1.2	Addressing security within supplier agreements	Y	Supply agreement includes security obligations for patient data.	Supplier & Third-Party Security Pack

A.15.1.3	Information and communication technology supply chain	Y	Information and communication technology supply chain risks of reviewed for hosted patient data systems.	Governance and Continuity Framework

A.15.2 Supplier Service Delivery Management

Control	Description	Adopted	Justification	Reference
A.15.2.1	Monitoring and review of supplier services	Y	Supplier performance is reviewed to maintain security of patient systems.	Supplier & Third-Party Security Pack
A.15.2.2	Managing changes to supplier services	Y	Changes to supplier services are reviewed for security impact	Supplier & Third-Party Security Pack

A.16 Information Security Incident Management

A.16.1 Management of Information Security Incidents and Improvements

Control	Description	Adopted	Justification	Reference
A.16.1.1	Responsibilities and procedures	Y	Defined roles and procedures exist for incident handling.	ISMS Operational Manual
A.16.1.2	Reporting information security events	Y	Staff report security events involving patient data.	Audit & Compliance Logbook
A.16.1.3	Reporting information security weaknesses	Y	Users are encouraged to report potential weaknesses.	Staff Handbook
A.16.1.4	Assessment of and decision on information security events	Y	Events involving health data are assessed and escalated.	Incident response SOP

A.16.1.5	Response to information security incidents	Y	Incident responses are in place to protect patient data.	ISMS Operational Manual
A.16.1.6	Learning from information security incidents	Y	Lessons learned from incidents are reviewed and documented.	Audit & Compliance Logbook
A.16.1.7	Collection of evidence	Y	Procedures ensure evidence is collected in response to incidents.	ISMS Operational Manual

A.17 Information Security Aspects of Business Continuity Management

A.17.1 Information Security Continuity

Control	Description	Adopted	Justification	Reference
A.17.1.1	Planning information security continuity	Y	Continuity plans address patient data during service disruption.	Governance and Continuity Framework
A.17.1.2	Implementing information security continuity	Y	Security measures are in place to maintain data availability.	Governance and Continuity Framework
A.17.1.3	Verify, review and evaluate information security continuity	Y	Information security continuity is reviewed and tested for patient data systems.	Governance and Continuity Framework

A.17.2 Redundancies

Control	Description	Adopted	Justification	Reference

A.17.2.1	Availability of information processing facilities	Y	Information processing facilities used for patient data have safeguards in place to ensure availability.	Supplier & Third-Party Security Pack

A.18 Compliance

A.18.1 Compliance with Legal and Contractual Requirements

Control	Description	Adopted	Justification	Reference
A.18.1.1	Identification of applicable legislation and contractual requirements	Y	legal and contractual obligations for patient data are identified.	Governance and Continuity Framework
A.18.1.2	Intellectual property rights	N	Not relevant.	N/A
A.18.1.3	Protection of records	Y	Patient data is protected as part of organisational records.	Governance and Continuity Framework
A.18.1.4	Privacy and protection of personally identifiable information	Y	Patient data is protected in line with privacy legislation.	Audit & Compliance Logbook
A.18.1.5	Regulation of cryptographic controls	Y	Encryption controls used for health data follow regulation.	Cryptographic control policy

A.18.2 Information Security Reviews

Control	Description	Adopted	Justification	Reference
A.18.2.1	Independent review of information security	Y	Security measures for patient data are periodically reviewed externally.	Audit & Compliance Logbook

A.18.2.2	Compliance with security policies and standards	Y	Compliance with patient data security policies and standards is verified through regular checks.	Information Security Policy Manual
A.18.2.3	Technical compliance review	Y	Technical controls are reviewed to ensure compliance.	Audit & Compliance Logbook

Appendix D.2.2: Statement of Applicability for Consent Records

Name of Organisation SOA ISO/IEC 27001:2017

Statement of Applicability: Consent Records

Main Controls for Adoption (for "Tolerate" Treatment Strategy)

	Control	Description	Adopted	Justification	Reference
Human Resource Security	A.7.2.2	Information security awareness, education and training	Y	Staff receive awareness training to support secure handling of consent records and data protection responsibilities.	Staff Handbook
Asset Management	A.8.2.1	Classification of information	Y	consent records are classified to ensure appropriate handling based on sensitivity and confidentiality.	ISMS Operational Manual
User Access Management	A.9.2.5	Review of user access rights	Y	Access rights to consent data are reviewed at regular intervals to maintain appropriate authorisation levels.	ISMS Operational Manual
System and Application Access Control	A.9.4.1	Information access restriction	Y	Access to consent records is restricted through system level controls to sure only authorised users can view or modify data.	ISMS Operational Manual
Operations Security	A.12.4.1	Event logging	Y	User activities involving consent records are logged sensual trace ability and support security and monitoring.	ISMS Operational Manual
Compliance	A.18.1.4	Privacy and protection of personally identifiable information	Y	Consent records containing personal data are protected in accordance with applicable privacy requirements.	Audit & Compliance Logbook